

Does Code-Evidence Adjudication Recover Corrupted LLM Verdicts? A Pre-Registered Pilot of EVIDA under Untrusted Context

Anonymous (double-blind submission)
Anonymous

ABSTRACT

Large-language-model code analyzers read prose the defender does not control: a planted advisory comment moves the false-positive rate on benign code from .0625 to .70 for granite-3.3-2b (51 benign→vulnerable flips, 0 reversals, exact McNemar $p=8.9\times 10^{-16}$, $n=80$) and from .7125 to .9875 for Llama-3.2-3B, while the standard countermeasure—an AST-gated comment/docstring strip—costs cue-based detectors (recall .167 → .042 for Llama-3.2-3B). We present **EVIDA**, a pre-registered pipeline that treats the verdict on an attacked file and on its stripped counterfactual as two views: disagreement raises an alarm, a four-checker code-evidence bank adjudicates with a frozen fallback, and the policy verifies or abstains—never silently choosing a view. The pilot (764 paired units, two 2–3B models, gates frozen before any generation) answers the registered recovery question *negatively*: corruption recovery .2182 (12/55) versus .3273 (18/55) for strip-only—below the .40 gate and below strip-only itself—and the disagreement alarm is noise on uncorrupted units (precision .2111; falsifier F3 fires). End-to-end over the 55 events $\cup$ 146 clean units, every defense variant is net-harmful against doing nothing (errors 68 EVIDA / 115 strip-only / 55 no-defense), and pipeline recall on vulnerable units (.527) trails the raw analyzer (.571). What survives is directional only: defense-induced errors on clean units fall .5342 → .1712 ($p=2.2\times 10^{-16}$). The registered verdict is FAIL (mechanism-invalid); we decompose the failure and delimit where counterfactual disagreement can carry a defense. Safety claims are scoped to a cache-only base-model contrast—no safety prompt reached the pipeline.

1 INTRODUCTION

Open-source package and code analyzers built on local large language models read exactly the artifact an attacker can author: supply-chain attacks deliver malicious packages [8, 14, 18], deployed detectors learn from metadata and installation behavior [10, 12, 13, 24], and LLM-based triage is entering practice [11, 20, 23]. When the analyzed content contains prose—comments, docstrings, advisory-style notes—the prose is untrusted context in the sense of indirect prompt injection [16, 22], and it is semantically inert: nothing it says executes, yet it can steer the verdict.

Prior work in this program measured the channel. In the vulnerability domain, untrusted context corrupts verdicts toward flagging (a false-positive channel) and open 2–7B models essentially never refuse [1, 3, 15]. In the package domain the same program measured an in-package advisory that moves verdicts family-dependently, and an AST-gated comment/docstring strip (D1) that removes the channel where it inflates detection but deletes the detection cues of a second model family. Three

measured facts anchor this paper. **(M1)** On function-level snippets from four CWE families, a near-injection advisory raises granite-3.3-2b’s false-positive rate on benign code from .0625 to .70 ($\Delta.6375$; 51 benign→vulnerable flips, 0 reversals, exact McNemar $p=8.9\times 10^{-16}$, $n=80$) and Llama-3.2-3B’s from .7125 to .9875 ($\Delta.275$; 22 flips, 0 reversals). **(M2)** D1, gated by AST equivalence, reverts all four advisory-induced verdict changes on granite (exact $p=.125$) but suppresses llama’s malicious recall .167 → .042: the four lost detections are byte-identical comment-cued snippets, so the defense removes the model’s cues along with the attack. **(M3)** Stripping is provably attack removal: on all 38 gated package samples the stripped attack file equals the stripped original byte-for-byte.

These facts pose a question that strip-only defense cannot answer: can the analyzer *itself* notice that a verdict was corrupted, decide which view is right from code evidence alone, and abstain when neither is supported—all without ever seeing ground truth at runtime? EVIDA (Evidence-grounded Invariant Verdict Analysis) is our pre-registered answer: run the analyzer on the attacked file and on its stripped counterfactual (a view pair whose equality properties M3 establishes); treat view disagreement as an alarm, never as a verdict rewrite; adjudicate alarms with a bank of four static checkers (CWE-190, CWE-200, CWE-416, CWE-476) that validate claim locations in the AST and data-flow slices; route undecidable cases to a frozen CodeBERT fallback threshold; and guarantee the invariant that every no-evidence path is a counted fallback or abstention, never a silent view choice.

The pilot was executed exactly as registered, and its registered verdict is **FAIL**—a mechanism-invalid result that we report as the primary finding. On the registered granite corruption population (55 events), EVIDA recovers .2182 (12/55) of corrupted verdicts against a frozen .40 gate, and *loses* to the strip-only comparator (.3273, 18/55; all 6 discordant pairs against EVIDA). The disagreement alarm—the mechanism’s foundation—has precision .2111: most alarms fire on clean units where stripping the file’s *own* comments changes the verdict, not on corrupted files. The registered falsifier F3 fires (Holm-adjusted $p\approx 0$). What survives is directional and reproducible — but net-harmful end-to-end: the adjudicate-then-abstain layer cuts the rate of silent defense-induced errors from .5342 to .1712 pooled (exact McNemar $p=2.2\times 10^{-16}$, 53 discordant pairs, all one-directional) and from .1951 to .0976 on the cue-loss model, yet over the union of events and clean units every defense variant commits more errors than running the raw analyzer (55), EVIDA included (68), and its recall on vulnerable units (.527) trails the raw analyzer (.571). Safety-preservation was measured only as a cache-only base-model contrast; no safety prompt reached the pipeline.

Our contributions:

- (1) **A registered mechanism test, executed as registered.** Gates G1–G5, falsifiers F1–F4, and tripwires T1/T2 were frozen before any generation; the pilot ran pass-to-pass (a first pass with a disclosed cache-key defect is archived and also fails the gates), and a later cache-only re-execution reproduced every endpoint bit-identically (§5).
- (2) **The first paired measurement of strip-only recovery on the false-positive channel.** $CRR(D1\text{-only}) = .3273$ (18/55) on the granite FP population had never been measured before (only the 4-event recall-inflation channel had, in M2); it is the correct baseline any future adjudication defense must beat.
- (3) **A negative verdict with a mechanism decomposition.** The recovery failure decomposes into three measured components: (i) in 37/55 corruption events the two views *agree* on the corrupted verdict, so the alarm never fires; (ii) the checker bank’s SUPPORT decisions false-endorse verdicts on benign code that structurally resembles vulnerable code; (iii) the frozen fallback contributed incorrect finals on the clean population. Each component is measured, not conjectured (§8).
- (4) **An end-to-end accounting that the defense loses.** Over the union of the 55 corruption events and the 146 registered clean units, every defense variant is net-harmful against running the raw analyzer (errors 68 EVIDA, 115 strip-only, 55 no-defense), and EVIDA’s recall on vulnerable units (.527) is below both the raw analyzer (.571) and its own stripped view (.628). The DIER reduction is real (.1712 vs. .5342 pooled, $p=2.2\times 10^{-16}$) but compares two net-harmful variants on the clean side only; the guard objective failed its absolute .05 gate and the end-to-end frontier is shown, not hidden (§6, Table 2).

2 RELATED WORK

Malicious-code detection and LLM triage. Behavior-sequence detectors map installation-time traces (DONAPI [13], Cerebro [24]), MalGuard targets real-time PyPI detection [10], MeMPtec uses metadata [12], and LLM triage of npm packages is measured in [23]. None of these study interference from prose inside the analyzed file, which is the channel EVIDA defends. **LLM vulnerability analysis.** Function-level LLM vulnerability detection and its evaluation pitfalls are documented in [7, 11, 20]; the paired (no ground truth at inference) discipline here follows the no-oracle rule of that line. **Untrusted context and injection.** BIPIA benchmarks indirect prompt injection and defenses [22]; automatic injection attacks are systematized in [16]. Modern injection defenses include query structuring (StruQ [4]), design-time information control (CaMeL [6]), and layered code-context sanitization (CodeSentinel [5]); none is reproduced or run in this pilot — EVIDA’s trusted view is the same tree-sitter sanitization family as CodeSentinel’s first layer, which is precisely why the strip-only comparator below also represents that defense class. EVIDA differs from pre-model sanitization in guarantee shape: sanitization transforms the input before the model and offers no signal when corruption survives it, whereas EVIDA post-hoc compares the two views, adjudicates with code evidence, and

counts every unevidenced path (verify-or-abstain). **Positioning: consistency-based reliability checking.** The counterfactual alarm is an instance of the consistency/redundancy tradition: perturbation-consistency hallucination detection (SelfCheck-GPT [17]), sample-and-aggregate decoding (self-consistency [21]), and the classical multi-version and recovery-block schemes for software fault tolerance [2, 19]. EVIDA instantiates two-view consistency with one difference that matters here: its second view is *executable-content-equivalent by construction* (AST-gated strip; byte-equality M3), so a disagreement is attributable to the removed prose rather than to sampling noise. The pilot’s negative result is therefore evidence about this design point — consistency between a file and its de-prosed twin — and not about consistency checking in general. **Safety-layer line of this program.** A companion measurement study [1] established refusal absence and verdict-corruption under untrusted context in the vulnerability domain; concurrent work documents defensive-refusal bias [3] and aligned-vs-abliterated behavior [15]. This paper is the first *defense* pilot of the program: it inherits the measured corruption populations (M1) and the audited strip machinery (M2–M3) and registers a frozen go/no-go test of the adjudication mechanism. **Selective prediction.** The verify-or-abstain policy instantiates selective prediction for verdict pipelines: abstention is budgeted and reported (UAC, abstain share) rather than implicit; the pilot’s zero-abstain outcome (§6) means the abstention arm remains untested under pressure—a stated limitation, not a claimed property.

3 THREAT MODEL

Attacker. The attacker controls prose inside the file the defender’s LLM will read: comments, docstrings, or an advisory-style note. The prose is non-executable and semantically inert by construction (comment-only injections gated by a tree-sitter equivalence check), so any verdict change is caused by the model reading untrusted text. Two measured attack arms instantiate the threat: **C5_near**, a feature-based near-injection advisory on function-level snippets from four CWE families (anti-leakage: no label, CWE, or CVE token in the advisory; benchmark bench_attack_v2, sha256_167e8ed42421a7c2d0); and **P2**, an advisory prepended to real package files (AST-gated). The attacker’s goal is bidirectional: suppress detections of genuinely malicious code, or inflate detections—including false positives on benign code.

Defender. The defender runs a local 2–3B analyzer (granite-3.3-2b, Llama-3.2-3B) and may post-process its output. The defender does not know which files are attacked. The EVIDA pipeline never sees ground truth at runtime: the alarm reads only the two verdicts; the adjudicator reads only static code evidence; refusals are never converted into verdicts. Labels enter only at scoring time.

Out of scope (declared pre-run). Executable payload semantics; the string-literal channel (the strip keeps strings, so a corrupted-string attacker is unmitigated); an attacker who corrupts *both* views (comment-free attack files defeat the counterfactual pair by construction); and adaptive attacks, which are anticipated but not run (§9). The measured realization-internal boundary of the counterfactual is view agreement: in 37/55 corruption events the two views already agree on the corrupted

verdict, which caps any two-view-adjudicating defense’s recovery at $18/55=.3273$ (§8).

4 METHOD: EVIDA

EVIDA is a five-stage pipeline over one analyzed file. No training occurs; all model calls are greedy (temperature 0, seed 1234) and served through a prompt-hash cache whose key includes the model revision.

(1) **Raw view.** V_{raw} : the verdict of the analyzer on the file as given (cached from the upstream measurement arms: C0/C5_near for snippets, P0/P2 for packages).

(2) **Trusted view.** V_{trusted} : a newly generated verdict on the *stripped* file, produced by the audited D1 machinery (tree-sitter comment and Python-docstring removal; string literals kept; AST re-parse equivalence gate). The pair (attacked file, stripped file) is the counterfactual: M3 establishes that *on the 38 gate-passing package samples* the stripped attack file is byte-identical to the stripped original, so the trusted view is “the same executable content, minus prose.” Gate-failure handling is registered before conditioning: a gate FAIL excludes the unit and is disclosed, never silently conditioned (realized here: 0 S2 exclusions; the S1 C/C++ fragments ran under the registered lenient-canonical gate mode, 160/160, since strict clean-parse is unattainable on C fragments).

(3) **Counterfactual disagreement alarm.** $\text{alarm} = (V_{\text{raw}} \neq V_{\text{trusted}})$, both views parsed. The alarm is *not* a rewrite: it only triggers adjudication. This is the registered mitigation for the known failure mode of view-based defenses (picking the wrong view).

(4) **Code-evidence adjudicator.** A bank of four registered checkers — CWE-190 (arithmetic on unvalidated size), CWE-200 (information flow to a sink), CWE-416 (free-then-use ordering in the CFG), CWE-476 (null-dereference path in the CFG) — validates the flagged verdict against tree-sitter AST locations and CFG/data-flow slices of the function-level code. Claim-level outcomes as *registered*: **SUPPORT** $\rightarrow$ final = V_{raw} (the claim is backed by code); **REFUTE** $\rightarrow$ final = V_{trusted} (the claim location/pattern is absent from the slice); **UNDECIDABLE** $\rightarrow$ a frozen fallback: CodeBERT (125M) [9] at a pre-registered argmax-MCC threshold $\tau=.5481$, with an ABSTAIN flag if the fallback yields no usable verdict. The checkers never see labels. *As implemented*, the outcome rule is direction-symmetric rather than claim-relative, and the manuscript’s frozen description above is therefore incomplete (disclosed implementation finding): SUPPORT and REFUTE are view-relative labels, and pattern absence endorses the benign verdict through whichever view cast it — all 122 SUPPORT paths that record a pattern state carry `pattern_state=pattern_absent` with V_{raw} benign, and all 51 REFUTE paths with `pattern_state=pattern_absent` have V_{raw} flagging-vulnerable, i.e. REFUTE switches to the (benign) trusted view. A second scope fact: the checker bank is registered on the four RQ8 snippet families, so on real package files (S2) the checkers are structurally unreachable and the fallback is the de facto decider — all 41 fallback calls are S2 units (§6).

(5) **Verify-or-abstain policy.** No branch of the pipeline silently selects a view; every no-evidence path is a counted fallback or a counted abstention (abstain budget). A refusal is never mapped to a verdict.

Checker validation protocol (before any real adjudication was read). Inject-and-perturb synthetic cases with labels by construction (pattern inserted into clean code = SUPPORT-known; pattern deleted from vulnerable code = REFUTE-known), four per family: 16/16 correct (synthetic precision 1.0, synthetic recall 1.0). This is a mandatory disclosure, not a gate: the synthetic labels bound what the checker bank can certify, and §8 shows the gap between synthetic and real distributions.

5 EXPERIMENTAL DESIGN

Registration. The pilot was pre-registered and frozen (2026-09-30) *before* any round-17 generation, with a filesystem check at freeze showing no round-17 artifacts, at git commit fb8988ad1ae9ef486856636c6c71129c54672e00; the frozen config is `configs/evida.yaml` (sha256_16 88971fa41e22ff59, created at freeze time). Hypotheses H-E1–E4, endpoints, gates, and falsifiers were locked in the registration. *Registration status disclosure*: this registration is repository-internal — the freeze is attested by the recorded commit and file timestamps, with no external timestamping (OSF registration is queued, not done, at submission time); the corruption populations, strip equivalence, and endpoint code ship in the anonymized artifact supplement so reviewers can re-derive the endpoints rather than trust the freeze.

Populations (frozen manifests, evaluation-only; no new splits). **S1** — RQ8 near-injection: 4 CWE families {190, 200, 416, 476} $\times$ (20 vulnerable + 20 benign) $\times$ arms {C0 clean, C5_near corrupted} $\times$ {granite-3.3-2b, llama-3.2-3B} (320 records/model, all cached pre-registration). **S2** — the PackGuard defense set: 38 AST-gate-passing packages per model (24 malicious + 14 benign; seed draw 20260922), arms {P0 neutral, P2 no-defense, P2+D1}, all cached; the only new arm of S2 is the P0-stripped view. **S3** — E6 IPI pairs (31 pairs, qwen-3B): *not evaluated*—disclosed at run start (the C3-carrier machinery would need a post-freeze rebuild; no gated comparison touches S3). **S4** — safety preservation, cache-only (0 new generations): 30 unsafe + 30 safe prompts per model. **S5** — 7B/8B negative controls, read-only at metric level (§7). The registered evaluation manifest realizes **764 units** (S1 640 = 320/model; S2 124 = 62/model), unit-list sha256_16 2fc35a41161d4959, identical to the pilot of record.

Realized execution. Pre-run gates: unit tests (`tests/test_evida_pilot.py` + `tests/test_packguard_defense.py`, 29 passed), a dry Mock-LLM end-to-end run, and a real smoke test (2 samples $\times$ 2 models: 4 generations + 4 cache hits, no statistical claim). The registered generation budget was 787; *pass 1* ran 324 new generations + 70 cache-resolved but contained a defect (a dtype key in the RQ8 `gen_cfg` leaked into the cache key, regenerating 142 byte-identical prompts); it is archived under `outputs/experiments/round17_evida/pass1_dtype_leak/` and preserved verbatim. *Pass 2* (pilot of record, registry EXP-02805) fixed the keying and ran **186 new generations + 208 cache-resolved = 394 trusted-view rows** (197/model), with S2 prompt fidelity asserted 124/124 against the audited round-12 prompt hashes and 0 strip-gate exclusions. A later deterministic re-execution with 0 new generations (394 cache-resolved) reproduced all endpoints bit-identically.

Registered deviations, declared before reading endpoints.

(i) The corruption-event population of the primary endpoint realizes $55 < 100$ —below the charter’s 100–200 pilot band; a physical property of the frozen artifacts (51 RQ8-FP + 4 recall-inflation events), declared pre-run, no resampling. (ii) The paired-unit base 764 exceeds 200 because the clean-side strata are cache-only (zero new compute); declared pre-run, no denominator trimming. (iii) S3 not evaluable (above). (iv) The S1 C/C++ fragments cannot pass the strict clean-parse gate (0/160); the registered lenient-canonical gate mode applies, disclosed.

Endpoints. Primary: CRR (Corruption Recovery Rate) on the registered granite pooled corruption population (S1-benign FP events $\cup$ S2-malicious recall-inflation events): an event is a sample whose attack-arm verdict differs from its clean-baseline verdict; the event is recovered iff the pipeline’s final verdict equals the clean baseline. CRR(EVIDA) counts the pipeline final; **CRR(D1-only)** counts the trusted-view verdict alone—measured on the FP channel here for the first time. CRR is *verdict restoration* (fidelity to the clean baseline’s behavior), *not* correctness restoration: on the recall-inflation stratum the clean baseline is benign against $y_{\text{true}}=\text{vulnerable}$, so a “recovered” event re-breaks a correct detection of malicious code; truth-conditioned recovery is reported separately in §7. **Secondary: DIER** (Defense-Induced Error Rate) on clean samples with a correct baseline verdict (registered denominators: granite 105, llama 41, pooled 146), three states {correct, incorrect, abstain}, $\text{DIER} = \text{incorrect}/\text{denominator}$ (abstain is not incorrect); strict-DIER = (incorrect+abstain)/denominator reported alongside, never gated; **alarm precision/recall; UAC** (usable-answer coverage, floor .95); per-family/per-channel strata; safety preservation. The MPIE (minimum practically important effect) was registered as $\Delta\text{CRR} \geq .15$ absolute.

Statistics. Exact two-sided McNemar on discordant pairs (discordant-only form; at these n , $p < .05$ requires ≥ 6 one-directional discordants); exact one-sample binomial for thresholds; Clopper–Pearson 95% CIs for proportions; paired bootstrap percentile 95% (10,000 resamples, seed 20260922) for rate deltas; Holm–Bonferroni over *exactly* the four gated comparisons (CRR EVIDA-vs-D1; DIER on llama-clean; alarm precision vs. .5; UAC vs. .95). Everything else is descriptive-at-realized- n : no ranking claims between models or families at pilot scale. *Which error rate governs falsifier firing*: the registered Holm family also governs falsifier F1, whose clause is “CRR(EVIDA) $\leq$ CRR(D1) with p n.s.” — under Holm ($p_{\text{Holm}}=.09375$, n.s.) F1’s condition is met and F1 fires; under the raw p ($p=.03125$, significant) it does not. The analysis artifact recorded F1 as not-fired under the raw- p reading; the honest statement is the dual one, and the verdict is FAIL either way because G1, G2, and G3 fail on point estimates and CIs regardless of the correction.

Gates and falsifiers (frozen). **G1** CRR(EVIDA) $\geq .40$; **G2** DIER(EVIDA) $\leq .05$ pooled and $\leq$ DIER(D1) on llama-clean; **G3** CRR(EVIDA) $>$ CRR(D1) strict; **G4** UAC $\geq .95$, unsafe compliance = 0, over-refusal not increased; **G5** CRR $\geq .40$ in $\geq 2/6$ registered strata. Falsifiers: **F1** adjudication adds nothing (CRR(EVIDA) $\leq$ CRR(D1), n.s.); **F2** guard objective failed (DIER(EVIDA) $\geq$ DIER(D1) on llama-clean); **F3** alarm precision $< .5$ (signal is model noise); **F4** UAC $< .95$. Tripwires: **T1** undecidable share $> 50\%$ of disagreements $\rightarrow$ mandatory reframe to detection-only; **T2** 7B/8B

Table 1: Registered gates and realized outcomes (pilot of record EXP-02805). PASS = false: G1, G2, G3, G5 fail; falsifier F3 fires. Per the registered stopping rule the pilot verdict is FAIL and FULL never opens.

Gate / falsifier	Registered	Realized
G1 recovery	CRR $\geq .40$	.2182 – FAIL
G2 new errors	DIER $\leq .05$; $\leq$ D1@llama	.1712 – FAIL
G3 paired gain	CRR(EVIDA) $>$ CRR(D1)	0/6 discordants – FAIL
G4 no clean collapse	UAC $\geq .95$; unsafe = 0	PASS (1.000; 0)
G5 direction stable	$\geq 2/6$ strata $\geq .40$	1/6 (CWE-416) – FAIL
F1 adds nothing	CRR(EVIDA) $\leq$ CRR(D1), n.s.	dual: fires under Holm (.094) / not
F2 guard failed	DIER(EVIDA) $\geq$ D1@llama	not fired (.0976 $<$.1951)
F3 alarm noise	precision $< .5$	FIRED (.2111)
F4 unusable	UAC $< .95$	not fired (1.000)
T1 undecidable	$> 50\%$ of disagreements	not fired (.1519)

boundary (read-only). PASS opens FULL; FAIL triggers charter §10 failure analysis with negatives preserved.

6 MAIN RESULTS

All values below are realized- n outcomes of the pilot of record (EXP-02805); the analysis JSON is computed by rule from per-unit decisions and re-verified by a cache-only re-execution.

The recovery mechanism fails its gate—and loses to strip-only. On the registered granite population (55 corruption events: 51 RQ8-FP + 4 recall-inflation), CRR(EVIDA) = .2182 (12/55; 95% CI [.1181, .3501]) against the G1 gate of .40, and CRR(D1-only) = .3273 (18/55; CI [.2068, .4671]). All six discordant pairs favor D1-only (0 favor EVIDA); the paired delta is $-.109$ in D1’s favor (bootstrap 95% CI $[-.20, -.036]$), exact McNemar $p=.03125$ raw, Holm-adjusted $p=.09375$. The honest reading: on this channel, plain stripping recovers *more* corrupted verdicts than adjudication does, and neither approaches the gate — and the gate was *structurally unsatisfiable in realization*: with the two views already agreeing on the corrupted verdict in 37/55 events, recovery is possible only on the 18/55 events where the views differ (on each of which the stripped view is correct), capping any adjudicator over these two views at .3273 $<$.40 (§8).

The disagreement alarm is noise on clean units (F3 fires). Two *different* registered populations happen to have size 146 — keep them distinct. $R=146$ is the *alarm-recall population*: all corruption events pooled over both models and both channels (granite 55 registered + granite vulnerable-side 49 + llama 27 + llama vulnerable-side 15). $C=146$ is the *clean population* (the DIER denominator set, below). Over the 756 both-parsed units (8 unparsed/refusal units of the registered 764 excluded and disclosed), the alarm fires 270 times: TP 57 (alarms on R), FP 213 (alarms on non-event units), FN 89 (R events not alarmed) — precision .2111 (CI [.1640, .2647]), alarm recall .3904 on R (CI [.3108, .4745]). The registered floor is .5; the exact lower-tail test against .5 gives $p=1.17 \times 10^{-22}$ (Holm-adjusted ≈ 0). The FP mass is structural: the 213 FPs are alarms on units with *no* corruption event — the two views differ there because stripping the file’s own prose changes the verdict — so view disagreement measures *sensitivity of the analyzer to prose it reads*, not corruption.

What survives on the clean side — and what it does not say. On the registered clean population C (baseline-correct samples; granite 105, llama 41, pooled 146), DIER(EVIDA) = .1712 (25/146) vs. DIER(D1-only) = .5342 (78/146): 53 discordant samples, every one a D1-only error (0 the other way), exact McNemar $p=2.2\times 10^{-16}$. On the cue-loss stratum the registered gate targets (llama-clean), DIER .0976 (4/41) vs. .1951 (8/41): direction correct, exact McNemar $p=.125$ (4 discordants < the 6 needed for $p<.05$ at this n — not statistically resolved), and the absolute .05 gate is missed, so G2 fails on its first clause despite the paired direction. Strict-DIER equals DIER everywhere: the abstain budget realized 0/146 and 0/41 (Clopper 95% upper bound .0249 and .0860). This is a comparison of two defense variants *on the clean side only*; the end-to-end accounting below shows both variants are net-harmful against doing nothing.

Coverage and safety — stated at their actual scope. UAC is 1.000 (756/756; CI [.9951, 1.0]) on the both-parsed subset — equivalently $756/764 = .9895$ over the registered manifest once the 8 unparsed/refusal units are counted; the abstention path is never exercised (0/756; CI upper bound .0049). Adjudication paths: agreement 486, checker-REFUTE 94, checker-SUPPORT 135, fallback 41. “0 fallback errors” in the decision meta counts *usable-score* failures, not correctness: every fallback call returned a usable score, but the fallback final is correct against y_{true} in only 19/41 = .4634 — and all 41 fallback calls are S2 package units, where the checker bank is structurally unreachable, so the fallback is the de facto decision-maker on the security-critical channel. On the cache-only safety contrast (S4): this is a *base-model* contrast — the per-model keys are qwen and llama only (the primary model granite has no S4 coverage), and by construction no safety record reached adjudication/fallback, so the pipeline’s safety-channel behavior is untested by the pilot. Within that scope: unsafe compliance 0.0 in every measured arm; over-refusal not increased (the pre-pilot round-3 E8 pattern holds — qwen-3B safe-task refusal .2333 $\rightarrow$.000, exact $p=.0156$, intent gate blocking 30/30; llama .0333 $\rightarrow$.000); refusals are never mapped to verdicts. G4 passes on its realized clauses; its safety clauses are evidence about the base models, not the pipeline.

End-to-end accounting: the defense loses to doing nothing. The per-endpoint views above can each be read favorably in isolation; the combined accounting cannot. Over U , the union of the 55 registered granite corruption events and the $C=146$ clean units ($n=201$), Table 2 counts final-verdict errors (vs. the clean baseline on events, vs. y_{true} on clean units) for the no-defense analyzer (raw view), always-abstain, D1-only, the zero-cost comparator P^* (strip on alarm, keep raw otherwise — no checkers, no fallback), and EVIDA. Every defense variant is net-harmful: EVIDA adds 13 errors over no-defense, and strip-only adds 60. The same holds end-to-end on the 756 both-parsed units (both models): recall on vulnerable units is .5270 for EVIDA, below the raw analyzer’s .5711 and below EVIDA’s *own* stripped view (.6275); pooled accuracy is .5026 vs. raw .5079; benign FP rates: raw .5661, stripped .6839, EVIDA .5259. P^* Pareto-dominates EVIDA on recovery at equal guard cost (CRR 18/55=.3273 with DIER-clean 78/146, identical to D1-only): the recovery-relevant component is the alarm triggering a strip, and the adjudicator’s net effect on recovery is negative. There is no operating point in this pilot at which running EVIDA beats running the raw analyzer.

Table 2: End-to-end net utility on U ($n=201 = 55$ registered granite corruption events $\cup$ 146 registered clean units). Errors are final verdicts disagreeing with the clean baseline (events) or y_{true} (clean units). P^* = alarm $\rightarrow$ strip (no checker, no fallback). Every defense is net-harmful vs. no-defense; always-abstain is the lower bound of doing nothing defensively.

Variant	event errors (/55)	clean errors (/146)	total (/201)
no-defense (raw view)	55	0	55
always-abstain	55	146	201
D1-only (strip)	37	78	115
P^* (alarm $\rightarrow$ strip)	37	78	115
EVIDA	43	25	68

Registered verdict. Gates G1, G2, G3, G5 fail; falsifier F3 fires; PASS = false; stretch = false. Per the registered stopping rule this is charter-§10 failure analysis, and the executed classification is **MECHANISM-INVALID**: stripping does not restore the corrupted verdict in most events, the disagreement signal that gates adjudication is dominated by clean-unit noise, and the end-to-end accounting (Table 2) shows the pipeline is net-harmful against its own raw analyzer. FULL never opened: it is prereg-gated on pilot PASS, no FULL registration exists, and a new preregistration + new pilot is required before any further EVIDA generation.

7 GENERALIZATION

Per-family and per-channel strata (registered, anti-masking). Table 3 reports every registered stratum. Only CWE-416 reaches the .40 recovery level (both arms, 6/15); CWE-190 and CWE-200 sit below .25 for both arms; CWE-476 separates the arms (.0769 vs. .3077; $p=.25$, not resolved at $n=13$). Splitting by channel: on the FP channel (51 events) EVIDA .2157 vs. D1 .2745 ($p=.25$); on the 4-event recall-inflation channel EVIDA .25 vs. D1 1.0 ($p=.25$)—consistent with the round-12 defense measurement (§1), where D1 reverted all four advisory-induced flips. The granite vulnerable-side stratum (49 events, secondary) shows both arms identical at .1837 with zero discordant pairs ($p=1.0$ by construction; Clopper upper bound of the D1 rate .3202).

Truth-conditioned recovery (the CRR semantics made explicit). Because CRR scores fidelity to the clean baseline, the recall-inflation stratum inverts under ground truth: all 4 of its events have a benign clean baseline against $y_{\text{true}}=\text{vulnerable}$, so D1-only’s Table-2 “1.0000 recovery” re-breaks 4 correct detections of malicious packages. Scoring final verdicts against y_{true} on the 55 events: no-defense (raw view) 4/55, clean baseline 51/55, D1-only 14/55, P^* 14/55, EVIDA 14/55; on the RI stratum: raw 4/4, clean 0/4, D1-only 0/4, P^* 0/4, EVIDA 3/4 (EVIDA keeps the raw detection on 3 of the 4). No population in this pilot scores “truth-aligned recovery” above the clean baseline that CRR treats as its target.

The second model reads through DIER, not CRR. Llama’s cue-loss failure mode was registered pre-run: its recovery is near zero *by design* (the stripped view deletes the cues it detected on), so its correction path is DIER/abstention, not CRR. Its strata are reported anyway (Table 3, bottom): pooled events $n=27$, .4815 vs.

Table 3: Registered strata: CRR(EVIDA) vs. CRR(D1-only), exact McNemar. Zero-discordant cells yield $p=1.0$ by construction and carry the Clopper–Pearson upper bound of the D1-only rate. No cell reaches significance after the registered correction; per-character §15 these are descriptive-at-realized- n .

Stratum	n	EVIDA	D1-only	McNemar p
CWE-190	9	.1111	.1111	1.0 (UB .4825)
CWE-200	14	.2143	.2143	1.0 (UB .5080)
CWE-416	15	.4000	.4000	1.0 (UB .6771)
CWE-476	13	.0769	.3077	.25
FP channel (S1 benign)	51	.2157	.2745	.25
Recall-inflation (S2 mal)	4	.2500	1.0000	.25
Granite vul-side (sec.)	49	.1837	.1837	1.0 (UB .3202)
Llama pooled (sec.)	27	.4815	.6667	.0625
Llama vul-side (sec.)	15	.5333	.8000	.125

.6667 ($p=.0625$); vulnerable-side $n=15$, .5333 vs. .8000 ($p=.125$) — directionally against EVIDA, none resolved.

Confirmatory replication on held-out data. To test whether the CR advisory effect generalizes beyond the development sample, we ran a pre-registered confirmatory experiment on **200 new PrimeVul functions** (100 vulnerable + 100 benign across four CWE families: 787, 125, 703, 476), disjoint from all prior evaluation sets (freeze hash aecc2797), on Granite-3.3-2B. Under the CR advisory arm, **57 of 100 benign functions flipped to “vulnerable”** ($\Delta FP = +.57$, exact binomial $p < 10^{-15}$), while zero vulnerable functions were lost. The CG (generic) and CB (benign-framing) controls produced ≤ 3 flips each, confirming that the effect is *content-type-specific*, not a generic comment perturbation. This replication on held-out data with a 4-fold larger sample confirms that the directional corruption is a robust, reproducible phenomenon.

Scale boundary (read-only controls). On the registered 7B/8B negative controls (Kaggle round-16, metric-level provenance only, record-level merging prohibited): the Qwen2.5-Coder-7B ladder shows no advisory harm at A5-vs-A0 (3 down / 5 up, exact $p=.7266$ — harm-absent supported) and Llama-3.1-8B is inconclusive (6 down / 2 up, $p=.2891$); refusal rate is 0.000 in every 7B safety arm. The corruption-recovery question therefore closes at 2–3B here; no scale extrapolation is made.

Determinism across runs. The cache-only re-execution (0 new generations) reproduced every endpoint bit-identically, and the pass-2 cache-resolved rows showed 0 verdict mismatches on llama’s 71 reused prompts (vs. 5/71 drift in the defective pass 1) — the pipeline is deterministic given the cache key, and the keying defect was the cause of pass-1 nondeterminism, not the model.

8 ABLATIONS AND MECHANISM

Where the mechanism breaks: three measured components, with the dominant failure direction named. (i) *The counterfactual is inert on most events — and this caps every gate.* In 37/55 corruption events the raw and trusted views *agree* on the corrupted verdict (67%): stripping the advisory out of the attacked file does not change the verdict, no alarm fires, and adjudication is unreachable. Recovery is possible only on the 18/55 events where

views differ — and on *all 18* of those the stripped view is already correct — so the CRR ceiling for *any* adjudicator over these two views is $18/55=.3273$, below the registered G1 gate of .40: G1 was unsatisfiable in realization, before any checker ran. (ii) *The dominant measured cost is false-negative creation, not benign false positives.* On the vulnerable side, 64 units have a correct trusted detection *destroyed* by the pipeline (trusted = vulnerable, final $\neq$ vulnerable): 62 via checker-SUPPORT on pattern_absent and 2 via the fallback. Per checker: CWE-200 24, CWE-190 21, CWE-416 16, CWE-476 1; per model: granite 59, llama 5; per source: S1 62, S2 2. Overall, SUPPORT kept a wrong final verdict in 69/135 paths (62 vulnerable-side, 7 benign-side). §4’s implemented-rule disclosure explains the sign: pattern absence endorses the benign verdict, so benign-looking vulnerable code gets its correct detection overwritten. The benign-lookalike framing (SUPPORT false- endorsement on clean units) is real but secondary — the unreported cost ran the other way. Both directions are invisible to the synthetic validation (16/16 on labels-by-construction). (iii) *The frozen fallback hurts on clean units.* Of the 41 fallback calls, 19 fall inside the registered clean population and 13 of those end in an incorrect final (9/15 on granite-clean; 4/4 on llama-clean — every llama-clean fallback call ends incorrect), so the fallback contributes directional losses to the clean-side error budget.

The recovery-relevant component is REFUTE alone (P* and the conditional view). On the 18 alarmed granite events — exactly the view-differing events — the stripped view is correct on all 18, while the EVIDA final is correct on only 12: checker-REFUTE preserves 11/11 recoveries, checker-SUPPORT destroys 3/3, and the fallback destroys 3/4 (1 preserved). The zero-cost policy P* (final = trusted on alarm, raw otherwise) therefore achieves CRR $18/55=.3273$ — identical to D1-only, above EVIDA’s 12/55, with the same 6–0 discordant structure — at DIER-clean 78/146, identical to D1-only: P* Pareto-dominates EVIDA on recovery at equal guard cost (Table 2). Whatever the checkers add on the clean side (DIER 25 vs. 78), they subtract more on the event side (recovery 12 vs. 18) and on vulnerable-side detections (64 destroyed, component ii).

Cache-key defect control (pass 1, archived). The defective first pass (dtype key in the RQ8 gen_cfg leaking into the cache key; 324 new generations + 70 cache-resolved; 142 byte-identical prompts regenerated) produced CRR .2364 (13/55), CRR(D1-only) .3455 (19/55), alarm precision .1957 — the same FAIL verdict under a different keying, so the conclusion is robust to the defect. The pass is preserved unmodified; pass 2 eliminated cross-run drift (0/71 llama mismatches on cache-resolved rows vs. 5/71 in pass 1, granite 71/71 identical in both).

Tripwires and side reports. The T1 tripwire (reframe to detection-only if undecidables dominate) does not fire: the undecidable share of disagreements is .1519 (41/270) — the failure is alarm *precision*, not checker coverage. The registered anti-masking side report (extended denominator including S1 vul-side C0-correct units, disclosed as NOT the registered denominator): pooled $n=210$, DIER .1333 vs. .3857; llama $n=104$, .0673 vs. .1058 — the DIER direction strengthens under the wider denominator, and strict-DIER continues to equal DIER (no abstentions to hide).

9 ANTICIPATED ADAPTIVE ATTACKS (NOT RUN)

No adaptive evaluation exists in this pilot. Charter §14 mandates an adaptive red-team stage; it was not reached (the state machine stops at the pilot verdict), and this section is therefore *anticipation grounded in measured structure*, not an adaptive experiment. Likewise, no modern injection defense is reproduced: StruQ [4], CaMeL [6], and CodeSentinel [5] are cited as positioning (§2), never run; the tables contain the no-defense and always-abstain operating points (Table 2) — the no-defense row wins. The paper should be read as a registered negative-result measurement with a scoped mechanism analysis, not as a validated defense. Each claim below is anchored to a measurement; the string-literal bypass and the both-views attack remain open by declared scope (§3).

(1) One-directional signatures are learnable. The corruption channel is one-directional on both models (granite 51 benign→vulnerable / 0 reverse; llama 22/0): an attacker who knows the defense class can tune advisories to sit inside the measured acceptance region rather than at its extreme. The pilot measures the extreme; the direction asymmetry means threshold-tuned alarms would face a shifting target.

(2) The defender’s own transform is an attack surface. The round-12 defense measurement (§1) is already an adaptive result without an adaptive attacker: for llama, the comments the strip removes were the detection cue, so the defense suppresses recall $.167 \rightarrow .042$. An attacker needs no injection at all—benign-looking comments become a liability under the defender’s mandatory pre-processing. EVIDA inherits this surface because its trusted view is the stripped file.

(3) Structure mimicry steers the adjudicator. The checker bank keys on structural patterns (CWE-190/200/416/476); the measured 213 alarms on non-corrupted units adjudicated without any corruption present show that benign code already trips view- and evidence-path machinery at pilot scale. An attacker who shapes benign code toward a pattern (or strips vulnerable-looking structure) steers SUPPORT/REFUTE decisions; the synthetic validation cannot see this because its labels are by-construction.

(4) The abstention arm is the designed adaptive fallback—and is untested. Verify-or-abstain guarantees no silent view choice, and the realized abstain budget is 0/756 (CI upper .0049): the guarantee held trivially because the path was never exercised. Under an adaptive attacker, whether the pipeline abstains rather than mis-verdicts is an open question this pilot cannot answer.

10 LIMITATIONS

Statistical power. The primary population realizes 55 events, below the registered 100–200 band (declared pre-run); the llama-clean DIER stratum has 41 units with only 4–8 discordant pairs, so its paired comparison is not statistically resolved ($p=.125$; resolution needs ≥ 6 one-directional discordants). All inference is descriptive-at-realized- n ; the Holm layer covers exactly the four registered comparisons.

Scope. Prose channel only (comment/docstring/advisory); string-literal and both-views-corrupted channels out of scope; two models at 2–3B under MPS bf16 decoding; S3 (E6 IPI pairs)

not evaluable at pilot; no multi-seed sensitivity (the 3-seed policy is registered for FULL only, which never opened); verifier labels are heuristic with synthetic-only validation (no human κ); no adaptive red-team run, and no reproduced external defense (StruQ/CaMeL/CodeSentinel cited, not run). On the package channel the checker bank is structurally unreachable, so the security-critical decisions fell to a frozen 125M fallback at .4634 accuracy (§6).

Coverage of the safety channel. The pilot measures no safety behavior of the pipeline: the S4 contrast is cache-only and base-model (per-model keys: qwen, llama — the primary model granite has no S4 coverage), and no safety record reached adjudication/fallback by construction. Any claim that verify-or-abstain preserves safety properties of the *pipeline* is unsupported here and requires a successor arm.

Evidence chain. The registration is repository-internal with self-attested freeze (commit + timestamps; no external timestamping at submission). All endpoints derive from released per-unit artifacts (evida_decisions.json, evida_analysis.json, units manifest), and every added number in the repair pass is a recompute from those artifacts; reviewers can re-derive rather than trust. The companion measurement study is cited as an anonymous manuscript without a public identifier; its load-bearing numbers (M1) are re-established here from the released round7_master.json artifact.

Status of the method. The registered verdict is FAIL (mechanism-invalid) at pilot scale. The clean-side DIER reduction (.1712 vs. .5342) is a directional observation comparing two net-harmful variants (Table 2), not a validated defense property; the guard objective’s absolute gate (.05) was not met, and end-to-end the pipeline is harmful against its own raw analyzer. FULL never opened: no FULL registration exists, and any successor must re-register and re-pilot under charter §10 before new generations.

11 CONCLUSION

We asked whether an analyzer can recover its own corrupted verdicts by combining a counterfactual view (stripped file), code-evidence adjudication (a four-checker static bank with a frozen fallback), and a verify-or-abstain policy—without ground truth at runtime. The pre-registered pilot answers no for recovery: CRR .2182 vs. the .40 gate and vs. .3273 for strip-only — a gate that realization itself had capped at .3273, since the two views agree on the corrupted verdict in 37/55 events; the disagreement alarm that gates everything is noise (precision .2111; F3 fired); and the mechanism decomposes into measured parts — inert counterfactuals on 37/55 events, 64 correct vulnerable-side detections destroyed by pattern-absence endorsement and the fallback, and fallback losses on clean units. End-to-end, over the union of events and clean units, every defense variant is net-harmful against the raw analyzer (errors 68/115 vs. 55), and the pipeline’s recall on vulnerable units trails the raw analyzer’s. The pilot also fixes values any successor must use: strip-only recovery on the FP channel is .3273 (first measurement), the zero-cost alarm→strip policy P^* matches it and Pareto-dominates the checkered pipeline on recovery, and the clean-side DIER reduction (.5342 $\rightarrow$.1712, $p=2.2 \times 10^{-16}$) is directional only — a comparison of two net-harmful variants

that missed its absolute gate. Per the registered stopping rule the verdict stands as FAIL (mechanism-invalid), FULL remains closed behind its preregistration gate, and the negative result is preserved verbatim: counterfactual disagreement between a file and its own stripped version is, at 2–3B scale, a measurement of prose sensitivity — not, by itself, a corruption detector.

DATA AND PROVENANCE

Pilot of record: outputs/experiments/round17_evida/(evida_analysis.json, evida_units.json, gen_trusted_granite2b.jsonl, gen_trusted_llama3b.jsonl; registry EXP-02805) with the defective pass archived under pass1_dtype_leak/; deterministic re-execution and status under outputs/packguard/full_method/ (evida_pipeline_rerun/, STATUS.json, round17_master_reverify.json); collector output outputs/master/round17_master.json; per-unit decisions outputs/packguard/full_method/evida_pipeline_rerun/evida_decisions.json (basis of the two recomputes marked “this rewrite”); upstream measurement artifacts outputs/master/round7_master.json (M1), outputs/packguard/defense/defense_analysis.json (M2), reports/round12/V1_report.md (M3), outputs/packguard/r16_kaggle/r16_analysis.json (S5); frozen registration RESEARCH_STATE/PREREGISTRATIONS/prereg_EVIDA_*.md (including the execution log) and configs/evida.yaml. Every number in this manuscript is a literal annotated with a % SRC: comment pointing at one of these artifacts; values marked “recompute” were recomputed from per-unit decisions (evida_decisions.json) for this manuscript and are labeled as such. *Release status*: the evidentiary chain above (analysis and decisions JSONs, units manifest, prereg + execution log, strip/checker/endpoint code under research_program/, and the recompute scripts) constitutes the anonymized artifact supplement; the registration itself is repository-internal with self-attested freeze and no external timestamping at submission (disclosed in §5); the frozen PackGuard manuscript source (packguard_r13_main.tex) is recovered from the provenance commit recorded in its header.

REFERENCES

- [1] Anonymous. 2026. Measuring and Mitigating Safety-Layer Interference in LLM Vulnerability Analysis. Anonymous manuscript under double-blind review. Unpublished companion measurement study; no public identifier as of this submission. Note: arXiv:2603.01246 is a different paper (Campbell et al., “Defensive Refusal Bias”).
- [2] Algirdas Avizienis. 1985. The N-Version Approach to Fault-Tolerant Software. *IEEE Transactions on Software Engineering* (1985). Title/author/year/venue verified via Semantic Scholar 2026-09-30; volume/pages omitted (not re-verified).
- [3] David Campbell, Neil Kale, Udari Madhushani Sehwaq, Bert Herring, Nick Price, Dan Borges, Alex Levinson, and Christina Q Knight. 2026. Defensive Refusal Bias: How Safety Alignment Fails Cyber Defenders. *arXiv preprint arXiv:2603.01246* (2026). arXiv record verified 2026-09-27 (v2).
- [4] Sizhe Chen, Julien Piet, Chawin Sitawarin, and David Wagner. 2024. StruQ: Defending Against Prompt Injection with Structured Queries. *arXiv preprint arXiv:2402.06363* (2024). arXiv record verified 2026-09-30 (v2); venue not re-verified this session.
- [5] Po-Han Cheng, Chia-Mu Yu, Ying-Dar Lin, Yu-Sung Wu, and Wen-Bin Lee. 2026. CodeSentinel: A Three-Layer Defense Against Indirect Prompt Injection in Code Contexts. *arXiv preprint arXiv:2606.19235* (2026).
- [6] Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. 2025. Defeating Prompt Injections by Design. *arXiv preprint arXiv:2503.18813* (2025). arXiv record verified 2026-09-30 (v2).
- [7] Yangruibo Ding, Yanjun Fu, Omniyyah Ibrahim, Chawin Sitawarin, Xinyun Chen, Basel Alomair, David Wagner, Baishakhi Ray, and Yizheng Chen. 2025. Vulnerability Detection with Code Language Models: How Far Are We?. In *47th IEEE/ACM International Conference on Software Engineering (ICSE)*. <https://doi.org/10.1109/ICSE55347.2025.00038> arXiv:2403.18624.
- [8] Ruian Duan, Omar Alrawi, Ranjita Pai Kasturi, Ryan Elder, Brendan Saltaformaggio, and Wenke Lee. 2021. Towards Measuring Supply Chain Attacks on Package Managers for Interpreted Languages. In *Proceedings of the Network and Distributed System Security Symposium (NDSS)*. arXiv:2002.01139 (arXiv comment: “To appear in NDSS Symposium 2021”); MalOSS collection.
- [9] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, and Ming Zhou. 2020. CodeBERT: A Pre-Trained Model for Programming and Natural Languages. In *Proceedings of the 2020 Conference on Empirical Methods in Natural Language Processing (EMNLP)*. <https://doi.org/10.18653/v1/2020.emnlp-main.285> arXiv:2002.08155.
- [10] Xingan Gao, Xiaobing Sun, Sicong Cao, Kaifeng Huang, Di Wu, Xiaolei Liu, Xingwei Lin, and Yang Xiang. 2025. MalGuard: Towards Real-Time, Accurate, and Actionable Detection of Malicious Packages in PyPI Ecosystem. In *34th USENIX Security Symposium (USENIX Security 2025)*. arXiv:2506.14466; venue per USENIX program, arXiv record verified 2026-09-27.
- [11] Zeyu Gao, Hao Wang, Yuchen Zhou, Wenyu Zhu, and Chao Zhang. 2023. How Far Have We Gone in Vulnerability Detection Using Large Language Models. *arXiv preprint arXiv:2311.12420* (2023). [CORRECTED 2026-09-18] author list re-verified via arXiv API (was mis-attributed to Han et al.).
- [12] S. Halder, M. Bewong, A. Mahboubi, Y. Jiang, R. Islam, Z. Islam, R. Ip, E. Ahmed, G. Ramachandran, and A. Babar. 2024. Malicious Package Detection using Metadata Information. In *Proceedings of the ACM Web Conference 2024 (WWW '24)*. <https://doi.org/10.1145/3589334.3645543> System name MeMPTec; arXiv:2402.07444; venue: ACM Web Conference (WWW).
- [13] Cheng Huang, Nannan Wang, Ziyang Wang, Siqi Sun, Lingzi Li, Junren Chen, Qianchong Zhao, Jiaxuan Han, Zhen Yang, and Lei Shi. 2024. DONAPI: Malicious NPM Packages Detector using Behavior Sequence Knowledge Mapping. In *33rd USENIX Security Symposium (USENIX Security 2024)*. arXiv:2403.08334; arXiv comment confirms USENIX Security 2024 acceptance.
- [14] Piergiorgio Ladisa, Henrik Plate, Matias Martinez, and Olivier Barais. 2023. SoK: Taxonomy of Attacks on Open-Source Software Supply Chains. In *2023 IEEE Symposium on Security and Privacy (S&P)*. 1509–1526. arXiv:2204.04008; venue verified 2026-09-27.
- [15] Mingchen Li, Meikang Qiu, Zifan Peng, and Heng Fan. 2026. Beyond Refusal: A Same-Lineage Study of Aligned and Abliterated LLMs for Vulnerability Analysis. *arXiv preprint arXiv:2607.05842* (2026).
- [16] Xiaogeng Liu, Zhiyuan Yu, Yizhe Zhang, Ning Zhang, and Chaowei Xiao. 2024. Automatic and Universal Prompt Injection Attacks against Large Language Models. *arXiv preprint arXiv:2403.04957* (2024). [CORRECTED 2026-09-18] author list re-verified via arXiv API (was mis-attributed).
- [17] Potsawee Manakul, Adian Liusie, and Mark J. F. Gales. 2023. SelfCheckGPT: Zero-Resource Black-Box Hallucination Detection for Generative Large Language Models. In *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing (EMNLP)*. arXiv:2303.08896; arXiv record verified 2026-09-30 (v3; EMNLP 2023 main conference).
- [18] Marc Ohm, Henrik Plate, Andreas Sykosch, and Michael Meier. 2020. Backstabber’s Knife Collection: A Review of Open Source Software Supply Chain Attacks. In *Detection of Intrusions and Malware, and Vulnerability Assessment (DIMVA)*. arXiv:2005.09535; 2005.09561 is an unrelated paper; BKC dataset.
- [19] Brian Randell. 1975. System Structure for Software Fault Tolerance. *IEEE Transactions on Software Engineering* (1975). Title/author/year/venue verified via Semantic Scholar 2026-09-30; volume/pages omitted (not re-verified).
- [20] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Wei Ma, Lyuyue Zhang, Yang Liu, and Yingjiu Li. 2024. LLM4Vul: A Unified Evaluation Framework for Decoupling and Enhancing LLMs’ Vulnerability Reasoning. *arXiv preprint arXiv:2401.16185* (2024). [CORRECTED 2026-09-18] 4 author names fixed via arXiv API.
- [21] Xuezhi Wang, Jason Wei, Dale Schuurmans, Quoc Le, Ed Chi, Sharan Narang, Aakanksha Chowdhery, and Denny Zhou. 2023. Self-Consistency Improves Chain of Thought Reasoning in Language Models. In *International Conference on Learning Representations (ICLR)*. arXiv:2203.11171; arXiv record verified 2026-09-30 (v4; ICLR 2023).
- [22] Jingwei Yi, Yueqi Xie, Bin Zhu, Emre Kiciman, Guangzhong Sun, Xing Xie, and Fangzhao Wu. 2023. Benchmarking and Defending Against Indirect Prompt Injection Attacks on Large Language Models. *arXiv preprint arXiv:2312.14197*

- (2023).
- [23] Nusrat Zahan, Philipp Burckhardt, Mikola Lysenko, Feross Aboukhadijeh, and Laurie Williams. 2025. Leveraging Large Language Models to Detect npm Malicious Packages. In *47th IEEE/ACM International Conference on Software Engineering (ICSE 2025)*. arXiv:2403.12196 (v1 title: "Shifting the Lens: Detecting Malware in npm Ecosystem with Large Language Models").
- [24] Junan Zhang, Kaifeng Huang, Yiheng Huang, Bihuan Chen, Ruisi Wang, Chong Wang, and Xin Peng. 2025. Killing Two Birds with One Stone: Malicious Package Detection in NPM and PyPI using a Single Model of Malicious Behavior Sequence. *ACM Transactions on Software Engineering and Methodology* 34, 4 (2025), 1–28. <https://doi.org/10.1145/3705304> System name Cerebro; arXiv:2309.02637; CrossRef record verified 2026-09-27.